Module 4 Assignment 4B:
Personal Inventory Database

Course: CS 85 - PHP Programming
Instructor: Vicky Seno

For this assignment, I created a PHP page that connects to a MySQL database using PDO and displays personal inventory records from an items table. I created the inventory_db database, added an items table, and inserted more than five sample inventory records.

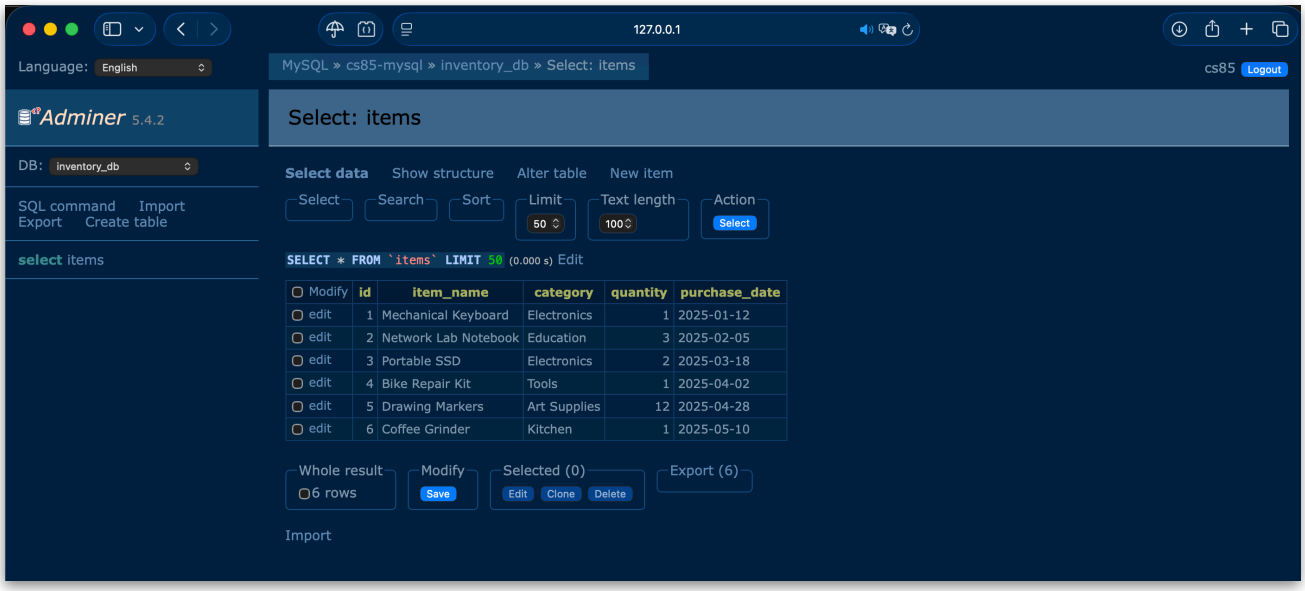
The page uses PDO prepared statements to retrieve inventory data securely. I also escaped output before displaying database values in the HTML table to help protect against XSS. In addition to the basic assignment requirements, I added filtering controls so the inventory can be searched by item/category, filtered by category and minimum quantity, and sorted in different display orders.

Test URL: http://127.0.0.1:8000/module4b/show_inventory.php

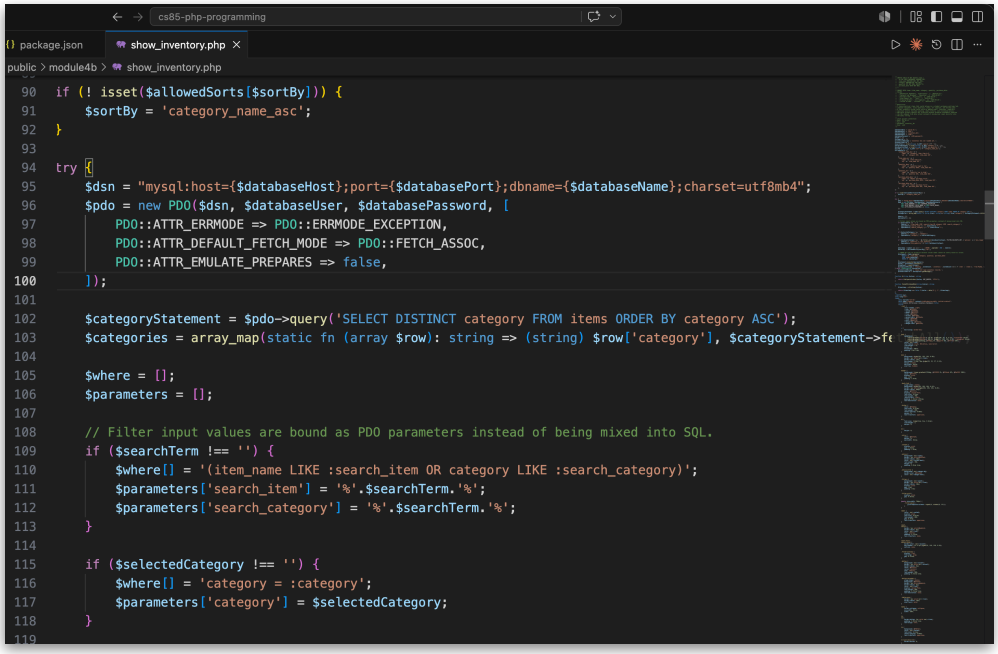
GitHub Repository: https://github.com/sergehall/cs85-php-programming/blob/main/public/module4b/show_inventory.php

Screenshots:

Screenshot 1: MySQL database and items table with sample records



Screenshot 2: show_inventory.php code showing PDO connection, prepared statement, and escaped output



```php
if (! isset($allowedSorts[$sortBy])) {
    $sortBy = 'category_name_asc';
}

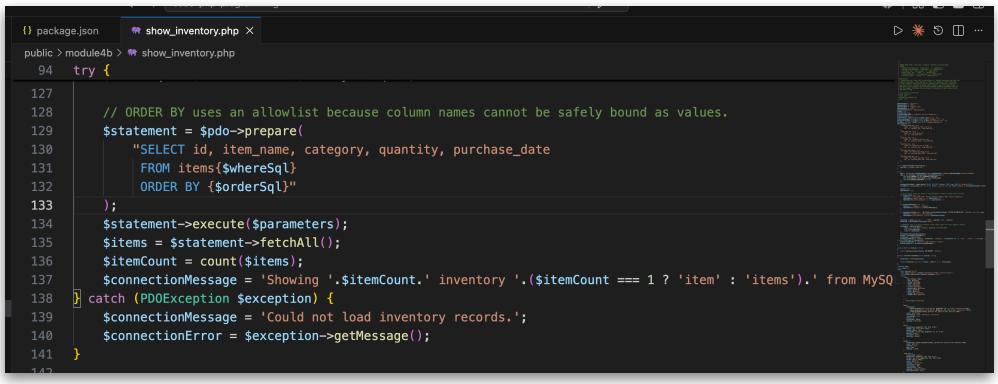
try {
    $dsn = "mysql:host={$databaseHost};port={$databasePort};dbname={$databaseName};charset=utf8mb4";
    $pdo = new PDO($dsn, $databaseUser, $databasePassword, [
        PDO::ATTR_ERRMODE => PDO::ERRMODE_EXCEPTION,
        PDO::ATTR_DEFAULT_FETCH_MODE => PDO::FETCH_ASSOC,
        PDO::ATTR_EMULATE_PREPARES => false,
    ]);

    $categoryStatement = $pdo->query('SELECT DISTINCT category FROM items ORDER BY category ASC');
    $categories = array_map(static fn (array $row): string => (string) $row['category'], $categoryStatement->fe

    $where = [];
    $parameters = [];

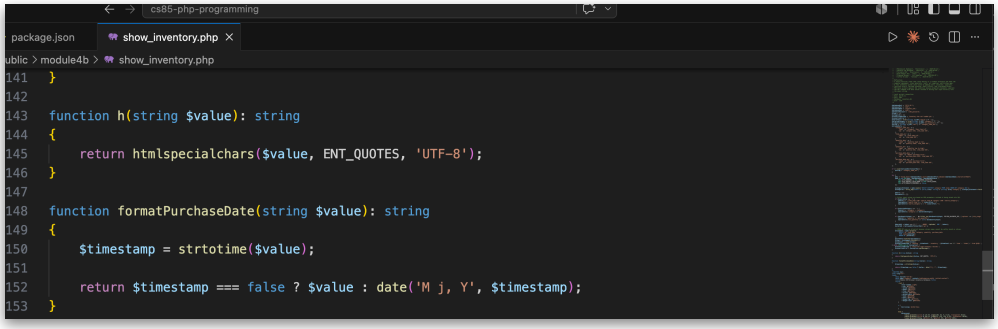
    // Filter input values are bound as PDO parameters instead of being mixed into SQL.
    if ($searchTerm !== '') {
        $where[] = '(item_name LIKE :search_item OR category LIKE :search_category)';
        $parameters['search_item'] = '%'.$searchTerm.'%';
        $parameters['search_category'] = '%'.$searchTerm.'%';
    }

    if ($selectedCategory !== '') {
        $where[] = 'category = :category';
        $parameters['category'] = $selectedCategory;
    }
```



```php
try {

    // ORDER BY uses an allowlist because column names cannot be safely bound as values.
    $statement = $pdo->prepare(
        "SELECT id, item_name, category, quantity, purchase_date
         FROM items{$whereSql}
         ORDER BY {$orderSql}"
    );
    $statement->execute($parameters);
    $items = $statement->fetchAll();
    $itemCount = count($items);
    $connectionMessage = 'Showing '.$itemCount.' inventory '.($itemCount === 1 ? 'item' : 'items').' from MySQ
} catch (PDOException $exception) {
    $connectionMessage = 'Could not load inventory records.';
    $connectionError = $exception->getMessage();
}
```



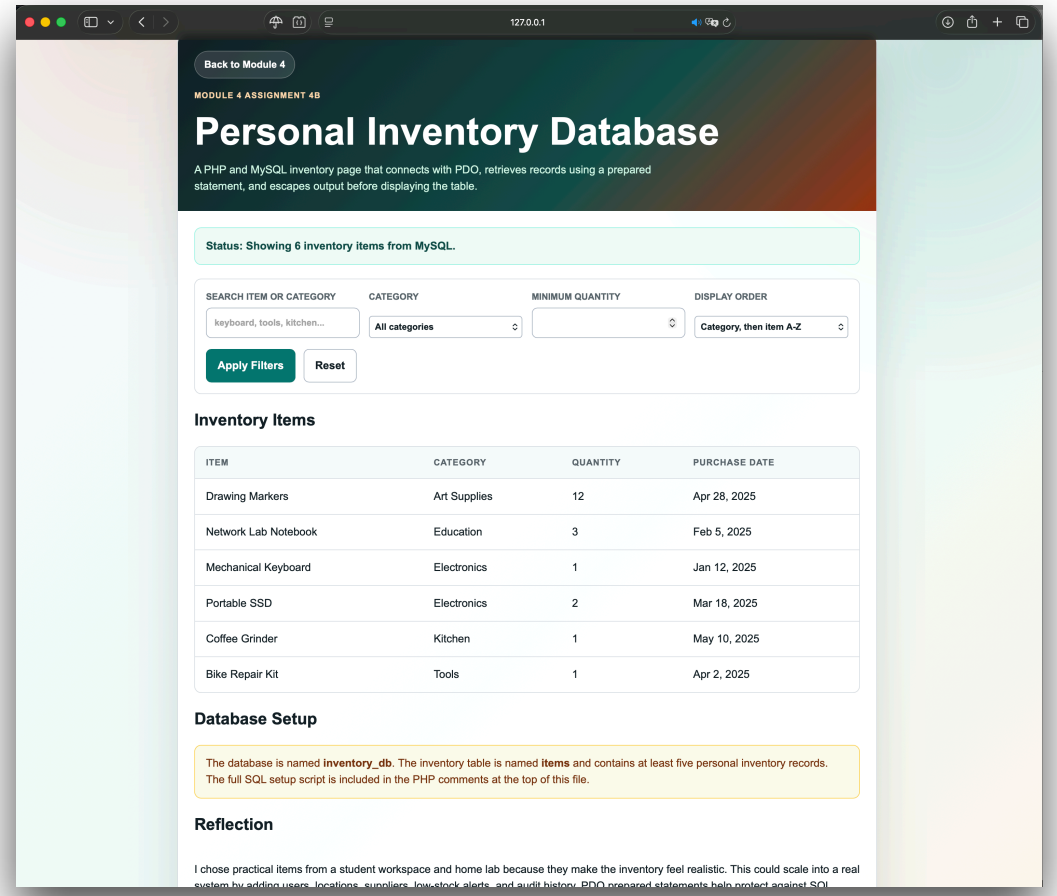
```php
}

function h(string $value): string
{
    return htmlspecialchars($value, ENT_QUOTES, 'UTF-8');
}

function formatPurchaseDate(string $value): string
{
    $timestamp = strtotime($value);

    return $timestamp === false ? $value : date('M j, Y', $timestamp);
}
```

Screenshot 3: Inventory page displaying records in the browser



Screenshot 4: Inventory page using filters/search/sort controls

